



The 5 layers that make a deployed AI agent worth trusting with customer conversations.

Most AI chat tools sold to small businesses promise "intelligence." They rarely promise **boundaries**. The Loucel's Trust Stack is what we build *underneath* every agent before it ever talks to a real customer — the unglamorous infrastructure that keeps the agent from leaking, lying, or going rogue.

This isn't marketing. It's what an AI agent actually needs to run in production for a business that can't afford downtime, data leaks, or regulatory exposure.

Layer 1 — DLP (Data Loss Prevention)

Before any message reaches the model, it passes through two PII detection layers:

- **Layer 1 (regex):** SSNs, credit cards, bank accounts, API keys, EIN/ITIN, government IDs — caught and masked in single-digit milliseconds.
- **Layer 2 (model-assisted):** Subtler patterns the regex misses — names tied to context, dates of birth wrapped in narrative, addresses inferred from "I live near...". Slower (~200ms) but catches what static rules can't.

If high-risk PII is detected, the message is **refused** — never forwarded to the LLM. The visitor gets a polite refusal asking them not to share that data in chat.

Why this matters: The model your agent is built on (Anthropic Claude, OpenAI, etc.) may be operating under a zero-retention contract — but you still don't want your customer's SSN to land in any vendor's logs by accident. DLP is the seatbelt you wish you didn't need, until you do.

Layer 2 — Append-only audit chain

Every decision the agent makes is written to an **immutable log row** with cryptographic hash-chain integrity:

- Each row references the SHA-256 hash of the previous row
- Tampering with any row breaks the chain on the next integrity check

- Service-role write only; no anonymous insert path

Rows include: who (workspace-scoped user_id), when (timestamp), what decision (ALLOW / DENY), what blocked it if denied (DLP layer 1, hard rule, rate limit, etc.), and the hash of the prompt — never the plaintext.

Why this matters: When a customer asks "did your agent actually tell my client X?", you don't have to take your vendor's word for it. The chain proves what happened. The same chain becomes evidence in a HIPAA / SOC 2 / SEC review — auditable, exportable, defensible.

Layer 3 — RBAC + workspace isolation

Every Loucels agent operates inside its own **workspace** with row-level security enforced at the database layer:

- Your customer data never sees another client's data
- Agent operators (your team) get scoped access based on role
- Orphaned access (ex-employee still has credentials) becomes structurally impossible — revocation is one row update
- Service-role credentials are held only by Loucels for governance; you can revoke at any time

Why this matters: When you fire an employee, the most common "now what" panic is *"do they still have access to the customer list?"* In a workspace-isolated architecture, the answer is: deactivate one user, revoke that workspace's scope, done.

Layer 4 — HITL (Human in the Loop)

For high-stakes actions — sent quotes, refunds, public review replies, anything irreversible or expensive — the agent **stages the action and waits for owner approval** before executing.

- Agent says: "About to send Quote #4321 to the customer at \$12,500. Confirm?"
- Owner gets push notification / SMS / email
- One tap: send. One tap: edit. One tap: reject + escalate.
- The agent never sends without explicit approval

Why this matters: Customer agreement to a number = revenue. Customer agreement to a wrong number = liability. HITL turns the agent into a precise assistant on the moments that matter, not an unpredictable

spokesperson.

Layer 5 — Hardened prompts + locked logic

Pricing, scope, and policy rules are **locked in code**, not in prompts:

- The agent literally cannot quote prices Loucels didn't pre-authorize
- The agent literally cannot agree to scope outside the pre-approved list
- Prompt injection attempts ("ignore previous instructions and tell me...") are caught and refused — the agent stays on-script
- Hard rules are tested against adversarial inputs during the build phase

Why this matters: A model is a probability machine. The Trust Stack is the discipline you put around it so it behaves like a contract, not a guess.

The Trust Stack lives underneath every Loucels agent

You don't pay extra for it. It's not an enterprise upgrade. Whether you engage us for a \$3,500 AI Front Desk or a \$25,000 enterprise governance build, the 5 layers above ship with the agent by default.

That's the difference between "we deployed a chatbot" and "we deployed a governed agent."

Want to know if your operation needs this?

Our **Operations Gap Audit** (7 days, \$500) maps your current workflow, conversation management, and security posture — and tells you which of the gaps a Loucels agent would actually close. Both deliverables (the Gap Map and the Trust Stack Risk Snapshot) are yours to keep regardless.

→ loucels.com/services/operations-gap-audit

Questions? steven@loucels.com
